

NCA Sponsored Training

Day 3 – Afternoon Session (Theory)

Network Security 2

Ahmed Didouh

Madinah

14/01/2026



rc3.kaust.edu.sa





Outline



1. MITM

- *ARP spoofing*
- *DHCP spoofing*

2. DNS

- *DNS cache poisoning*
- *DNS DDoS amplification*

3. DoS

- *SYN Flood (TCP)*
- *Smurf Attack (ICMP Flood)*
- *Trinoo (DDoS)*
- *Case study*

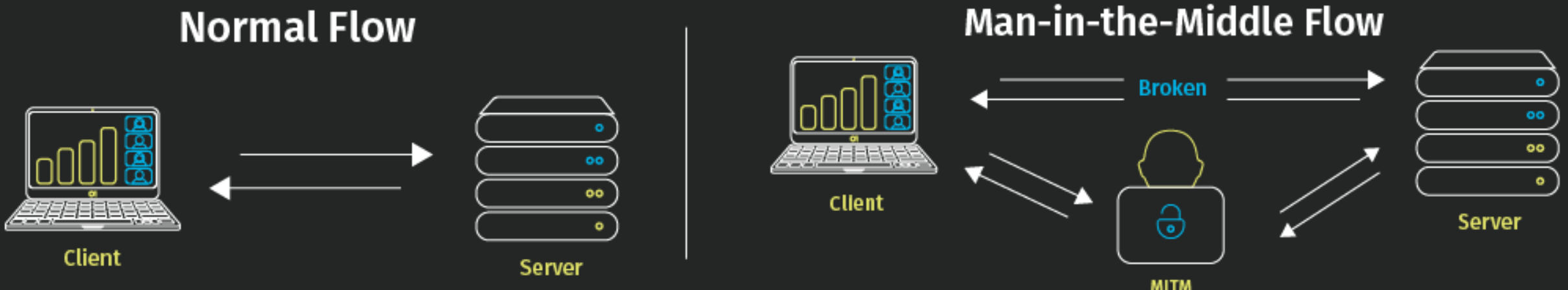


Man In the Middle Attacks (MITM)



What is an MITM

Man-In-The-Middle Attack (MITM) is a attack where the attacker intercepts the communication to read or alter the data between two parties who believe they are directly communicating with each other.





Man In the Middle Attacks (MITM)



Gaining Access to your bank account

1. The attacker sets up a fake chat service that mimics that of a well-known bank.
2. Using knowledge gained from the data intercepted in the first scenario, the attacker pretends to be the bank and starts a chat with the target.
3. The attacker then starts a chat on the real bank site, pretending to be the target and passing along the needed information to gain access to the target's account.

Man-in-the-Middle Attack Example





Is it serious? Real world MITM



- In 2011, Dutch registrar site DigiNotar was breached, which enabled a threat actor to gain access to 500 certificates for websites like Google, Skype, and others. Access to these certificates allowed the attacker to pose as legitimate websites in a MITM attack, stealing users' data after tricking them into entering passwords on malicious mirror sites. **DigiNotar ultimately filed for bankruptcy as a result of the breach.**
- In 2017, credit score company Equifax removed its apps from Google and Apple after a breach resulted in the leak of personal data. A researcher found that the **app did not consistently use HTTPS**, allowing attackers to intercept data as users accessed their accounts.



Why this is unambiguously MITM



- DigiNotar (2011) — Classic, Full MITM (Cryptographic MITM)
- What happened (technically)
 - *DigiNotar (a Certificate Authority) was compromised*
 - *Attackers **issued valid TLS certificates** for domains like google.com*
 - *Browsers **trusted these certificates***
 - *Users connected over HTTPS **without warnings***
 - *Attacker decrypted and re-encrypted traffic transparently*
- Why this is unambiguously MITM
 - *This matches the **known definition** of MITM:*
 - *An attacker secretly intercepts and relays communications while both parties believe they are communicating directly.*



Why this is considered MITM



- **Key properties present:**
 - Interception
 - Impersonation
 - Decryption of encrypted traffic
 - No user awareness
 - Trust infrastructure abuse

A MITM attack occurs when an attacker **positions themselves LOGICALLY between two communicating parties**, regardless of physical or network proximity.



Types of MITM



- **Address Resolution Protocol (ARP) Spoofing**
- **Dynamic Host Configuration Protocol (DHCP) Spoofing**
- **Domain Name Server (DNS) Poisoning/Spoofing**
- HTTPS Spoofing
- SSL stripping
- Rogue Access Point
- IP Spoofing
- Email Hijacking
- ..



MITM on Address resolution protocol - ARP



What is ARP?

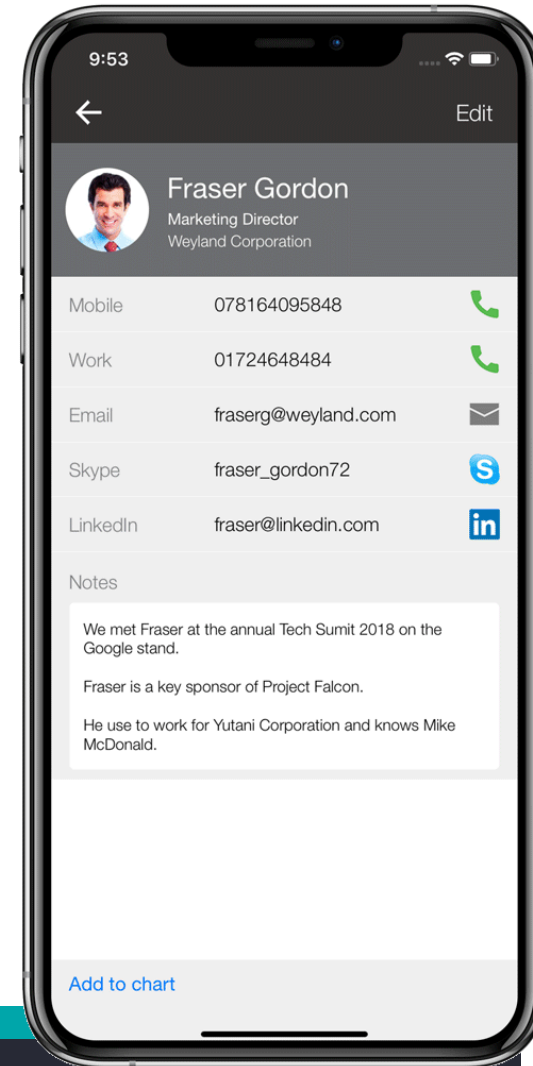
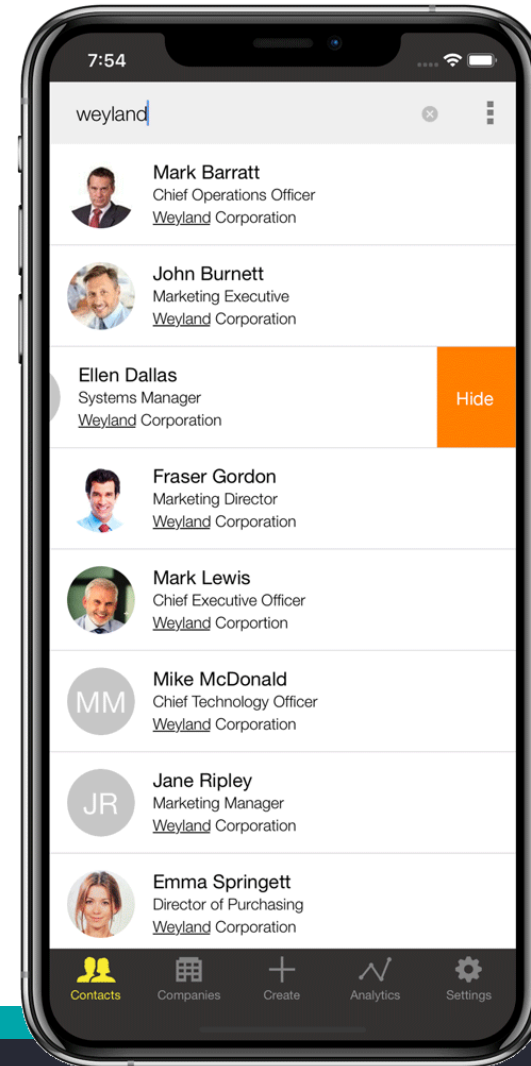
A protocol used to map IP address to MAC address

Note:

- IP is a protocol for the Internet
- MAC is a protocol for a Network

Think of it as an phone address book

What is the Mobile number of Fraser?



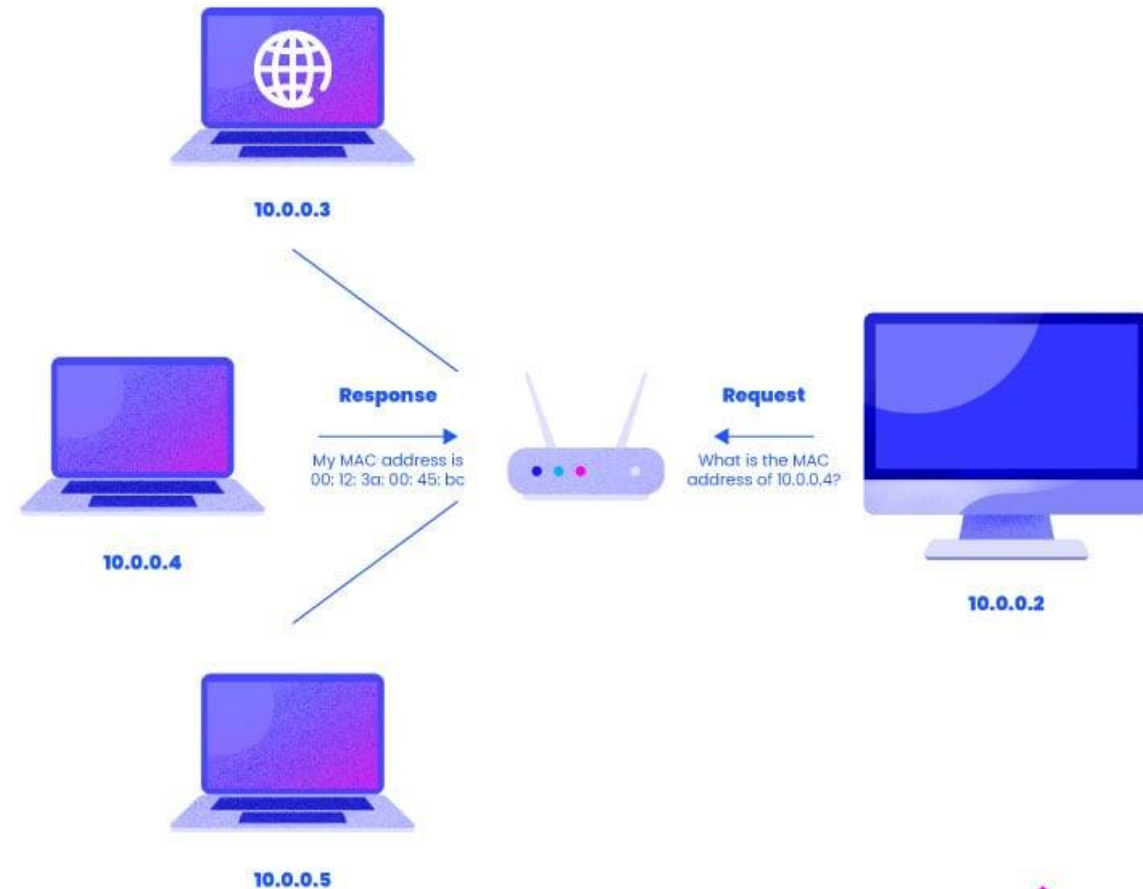


MITM on Address resolution protocol - ARP



HOW ARP works?

1. Computer1 asks the network:
what is the MAC of IP 10.0.0.2?
2. Router sends query to Computer2 10.0.0.2
3. Computer2 10.0.0.2 reply to Computer1
with MAC: 00:12:3cc:00:45:bo

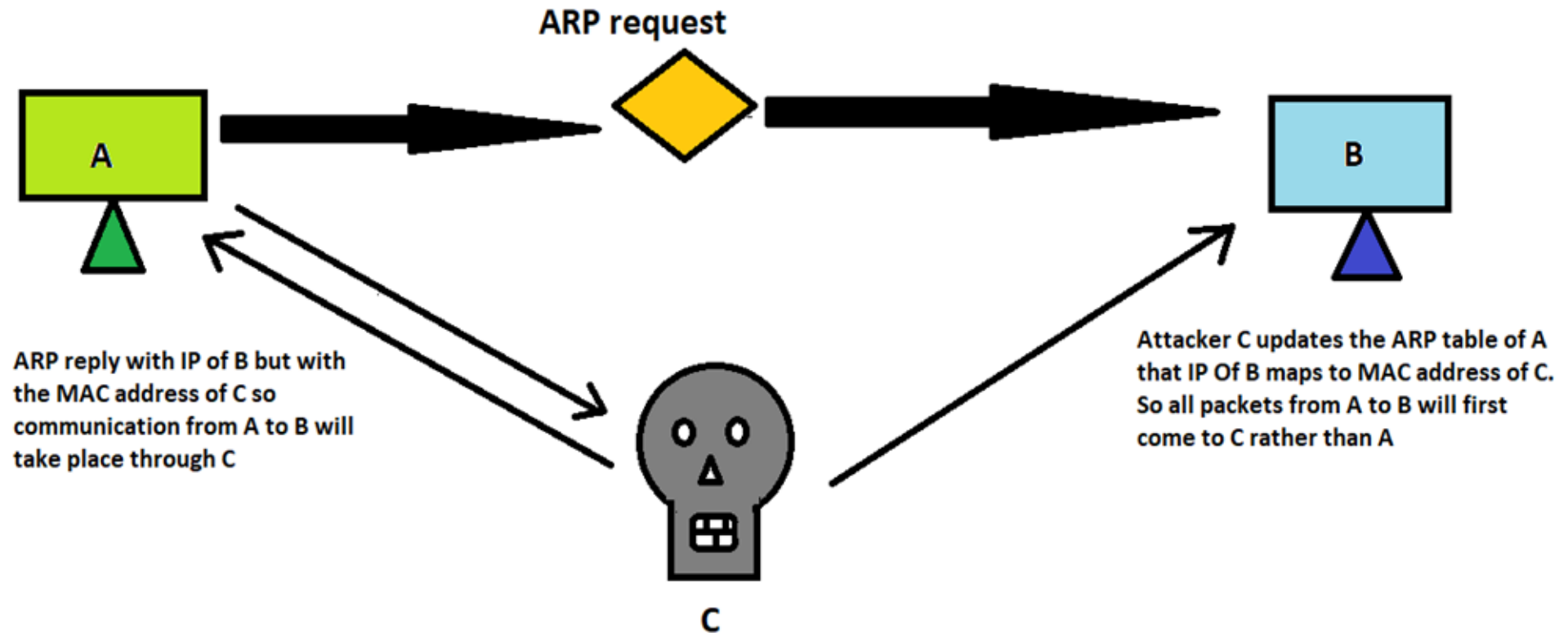




MITM on Address resolution protocol - ARP



ARP Spoofing





MITM on Address resolution protocol - ARP



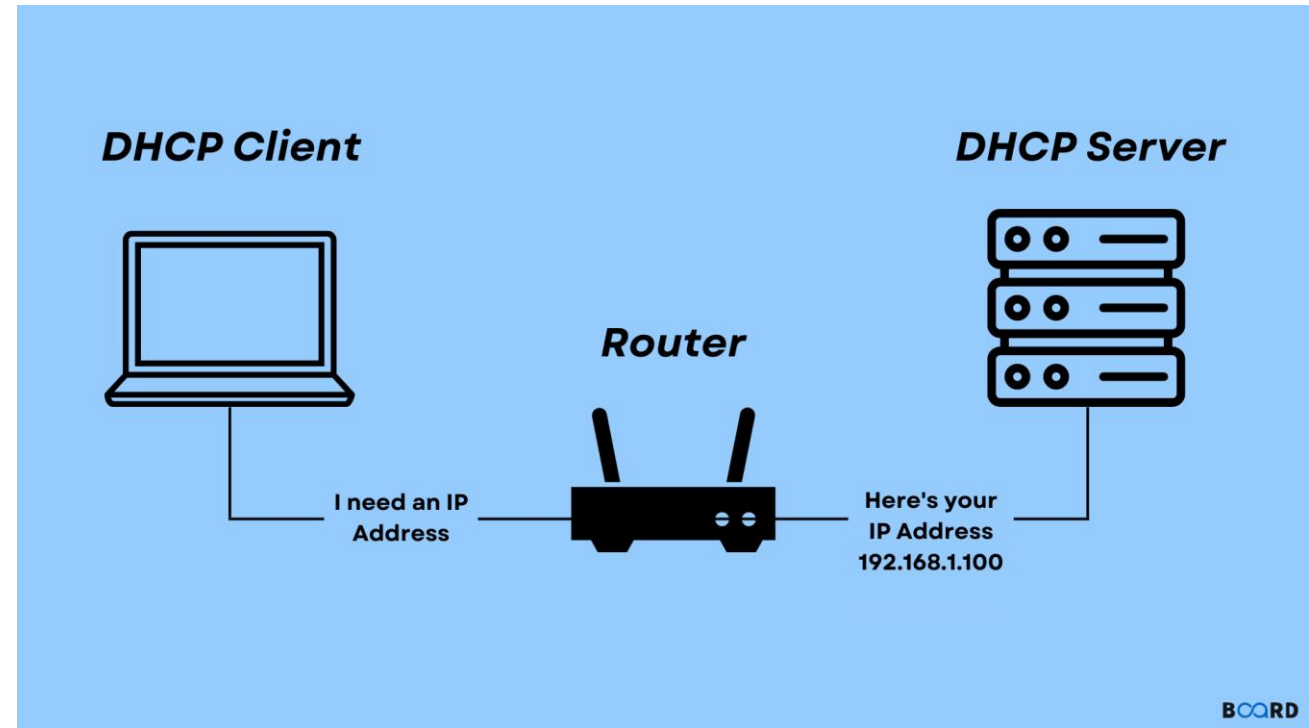
ARP Spoofing Impact

- Network: can see or modify all unencrypted data
- Web HTTP: this is unencrypted and contains no authentication. Therefore, all HTTP traffic can be trivially monitored/modified by the attacker
- Web-HTTPS: this uses authentication and encryption (e.g. SSH, SSL/TLS). The attacker could use a custom certificate. This would present a certificate warning message in the user's browser and likely alert the user to the attack. Luckily for the attacker, most users would ignore the warning and continue – thus exposing all of their data.



What is Dynamic Host Configuration Protocol (DHCP)?

A network protocol used to automatically assign IP addresses and configurations in a network



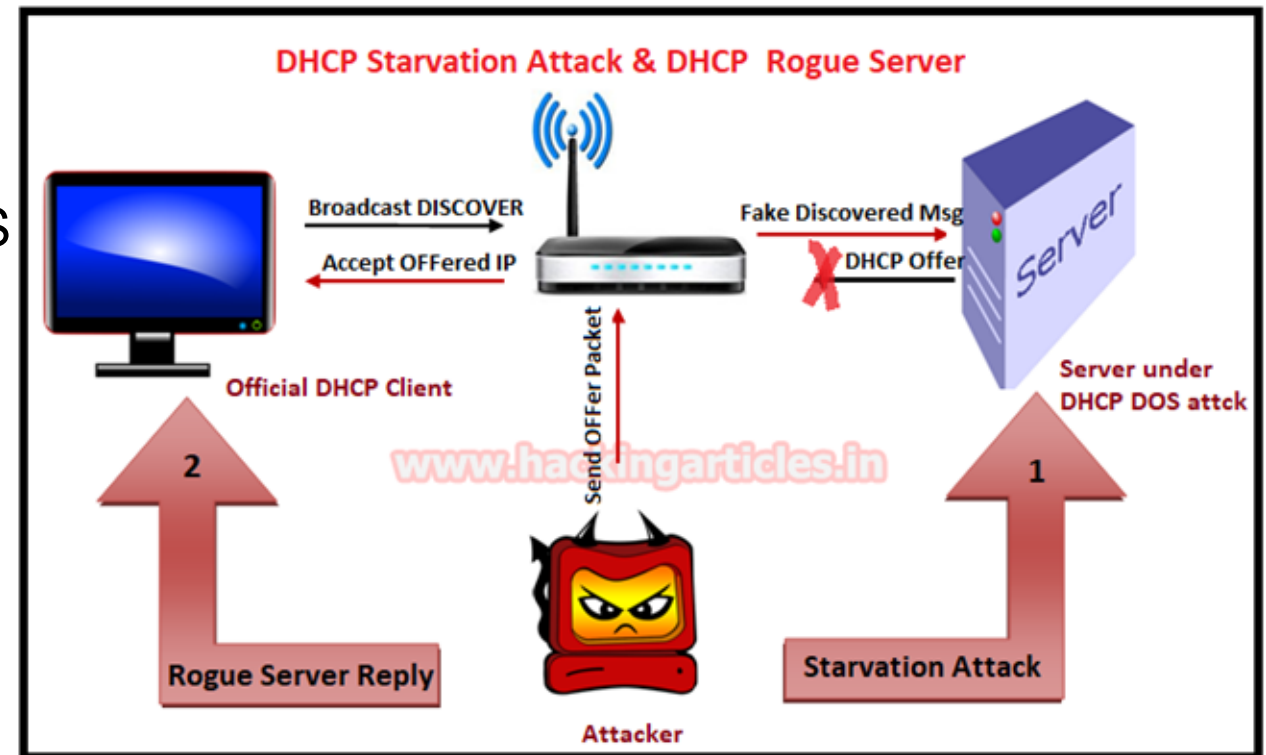


DHCP Spoofing

Pretend to be a DHCP (rogue) server faster than the real DHCP server

Steps

1. DHCP client requests new IP
2. Block/delay the DHCP server (e.g., DoS)
3. DHCP rogue server proposes and IP & new network configuration Gateway
4. All traffic going outside is redirection to the attacker's computers/servers





MITM on DNS



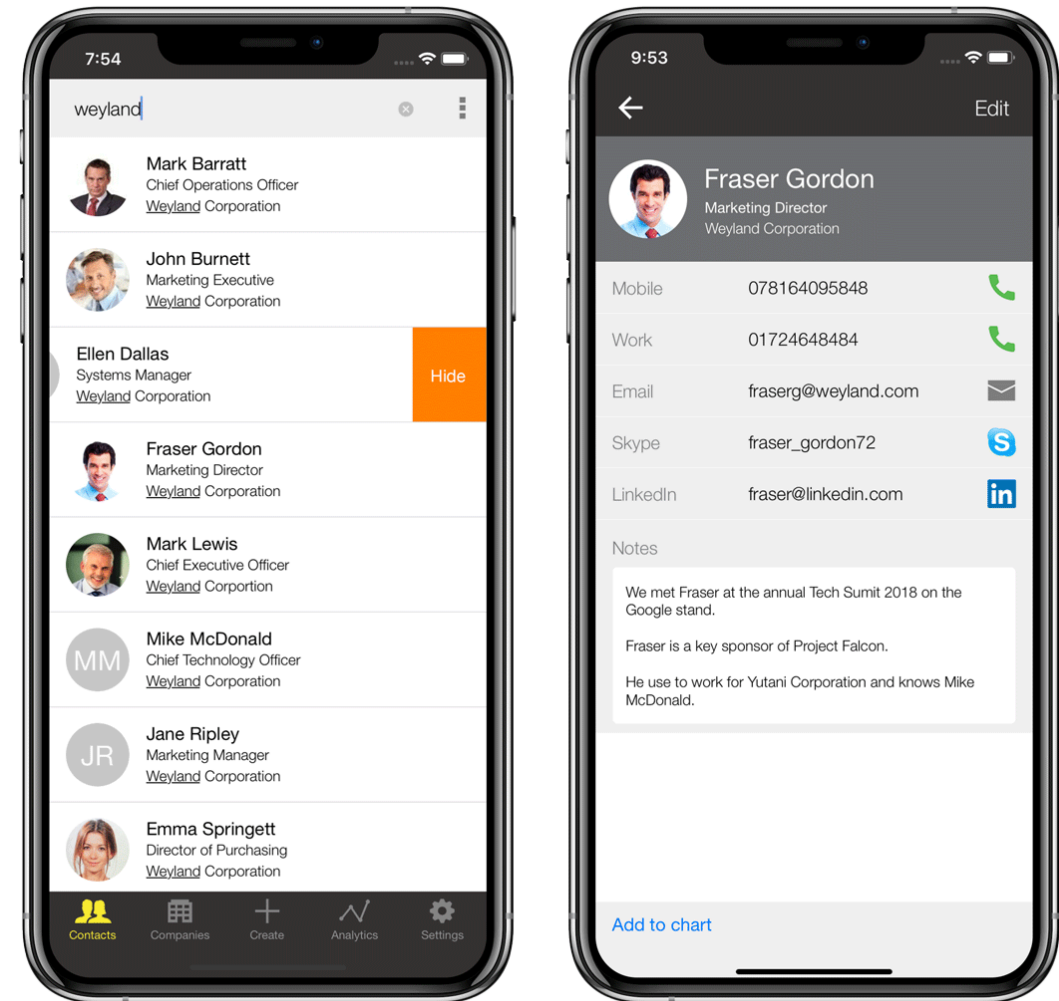
What is Domain Name System (DNS)?

A Distributed System used to map
Domain names to IP

Example.com -> 93.184.216.34

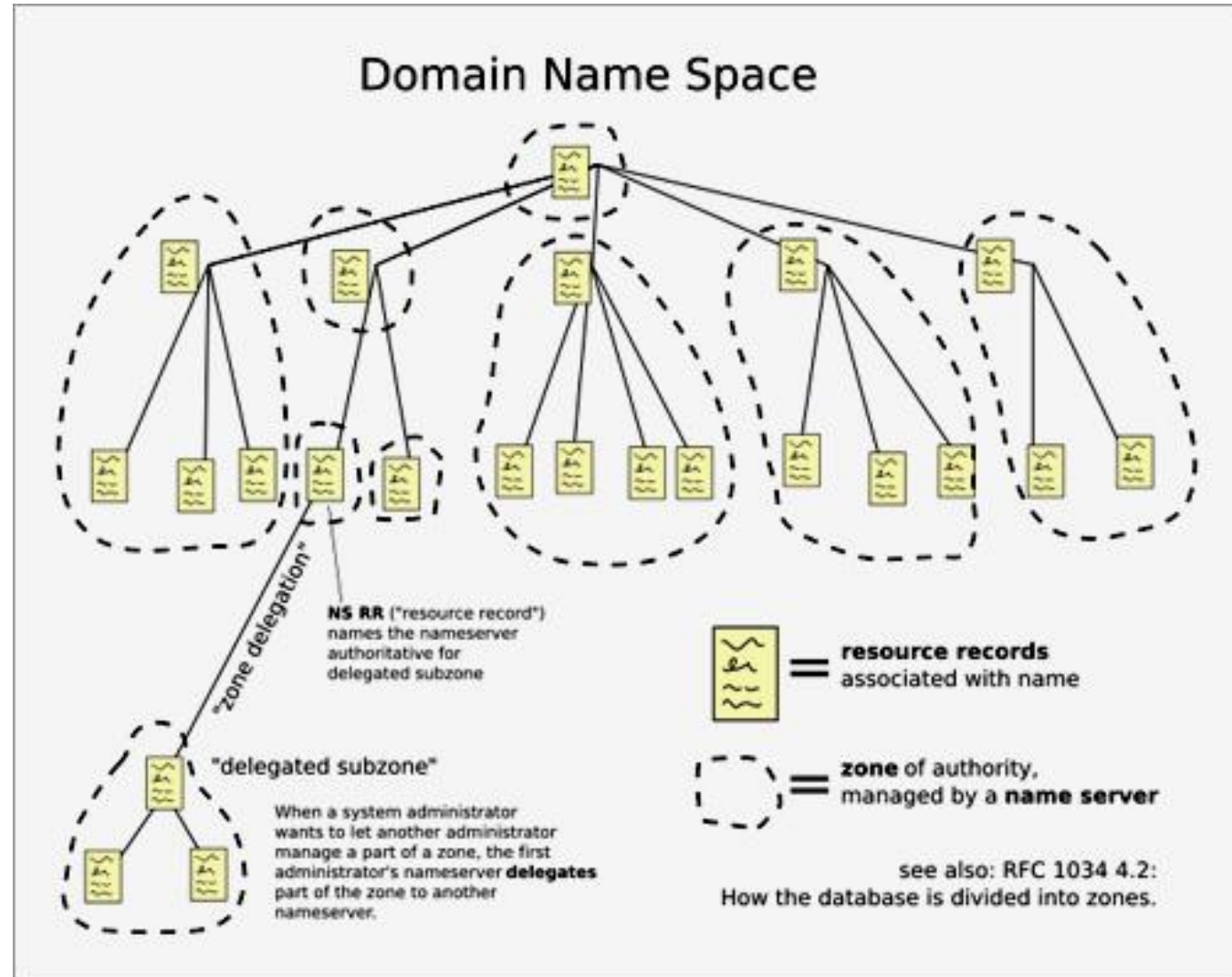
Again, think of it as an phone address book

What is the Mobile number of Fraser?



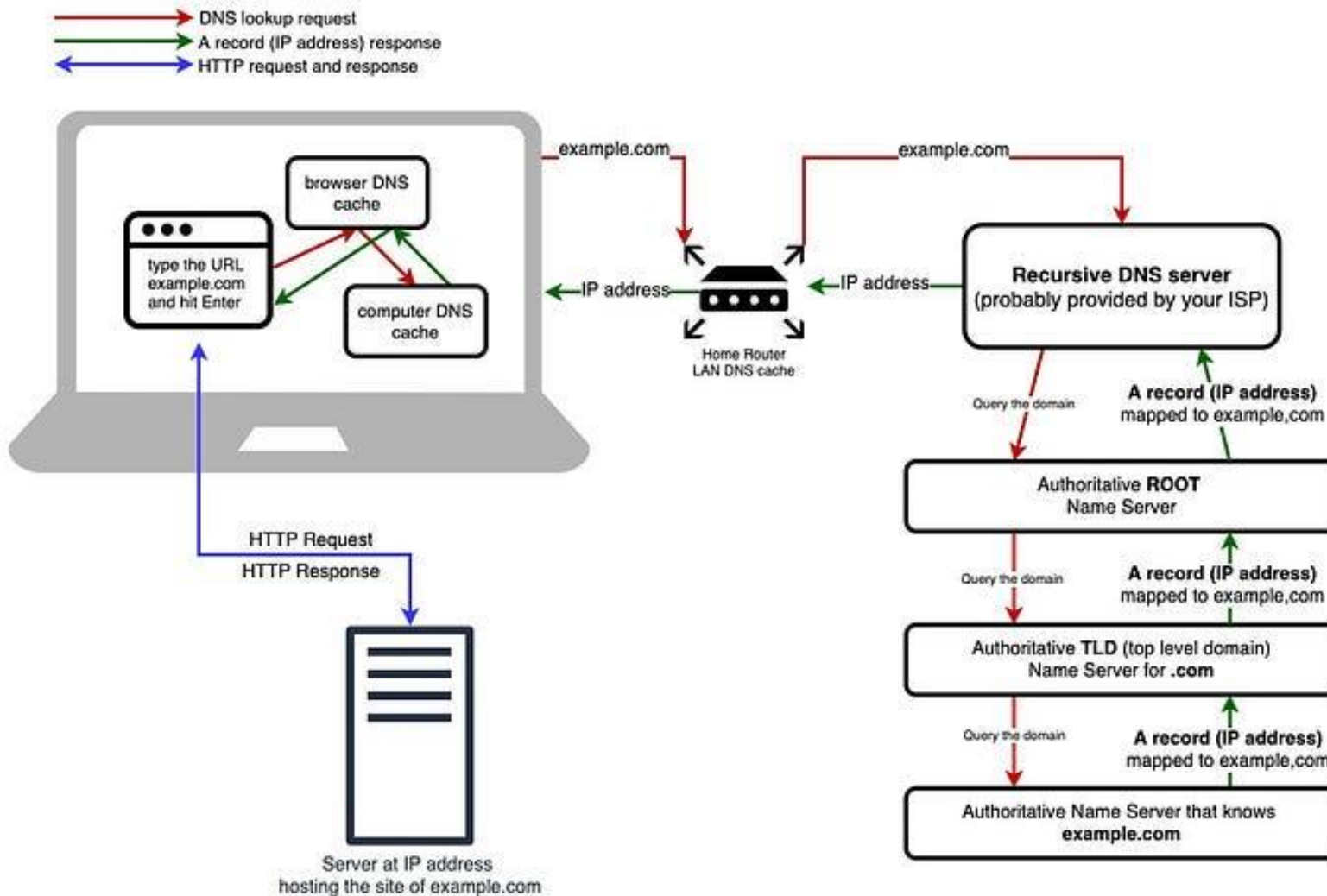


DNS Hierarchy





DNS Lookup





DNS attack types

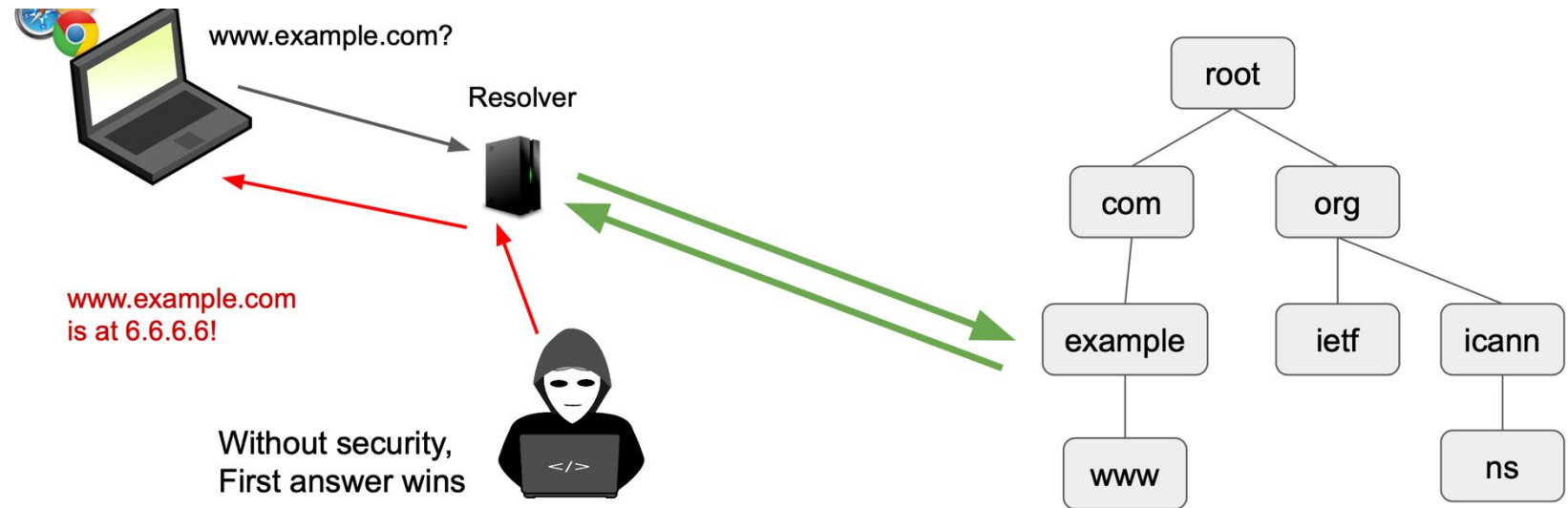
1. Zone File Compromise
2. Zone Information Leakage/DNS Footprinting
3. DNS Amplification Attack
4. DNS Client flooding
5. DNS Cache poisoning
6. DNS Vulnerabilities in Shared Host Environments
7. DNS Man in the Middle Attacks - DNS Hijacking
8. Typosquatting

Main issue: No authentication or encryption are considered at all in DNS protocol



DNS cache poisoning

- Just **flood the DNS resolver** with response packets and hope they accept them
- Possibly **guessing IP/protocol values** (name, source address, DNS ID field)
- Answer is cached for **TTL chosen by the attacker**

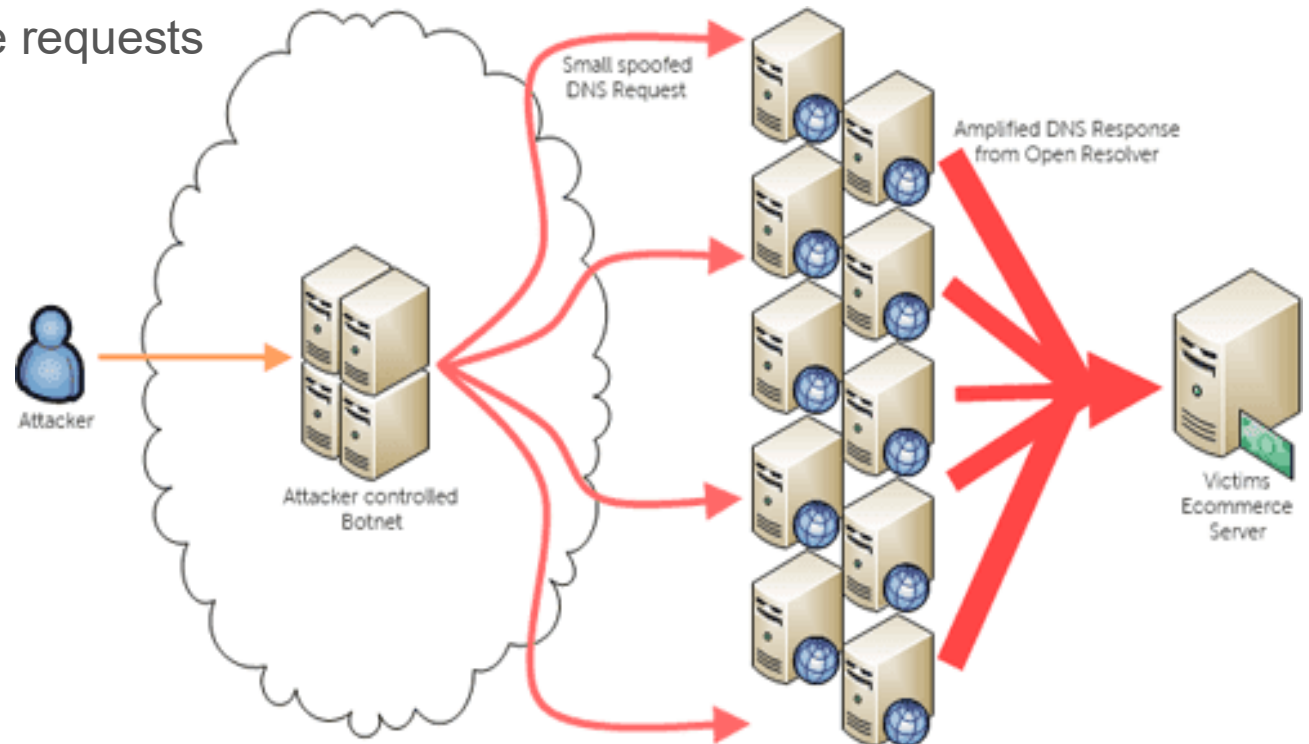




Using DNS for DDoS Amplification attacks

- DNS primarily uses the (spoofable) UDP protocol
- Most DNS responses are larger than the requests
- DNS is used in reflection attacks

See DDoS next





DNS mitigation

Rethink the protocol with security consideration

Record authentication:

- DNSSEC: DNS records signed by their authoritative source

Path security: Point-to-Point integrity and encryption

- DNS over TLS
- DNS over HTTPS



Denial of Service (DoS) Attack

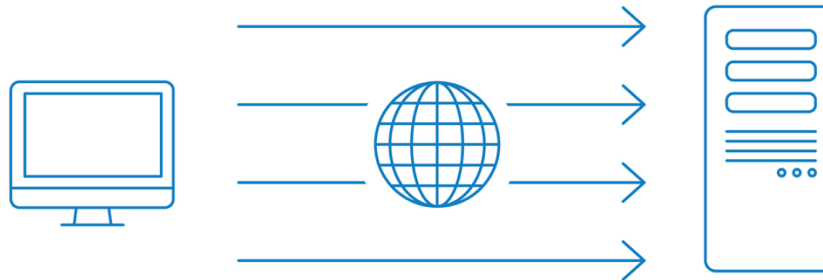


What is a Denial of Service (DoS) attack?

A DoS (Denial of Service) attack aims at preventing, for legitimate users, authorized access to a system resource or the delaying of system operations and functions. It happens mainly through exhausting the resources of the system.

Example:

- "Flood" a network, thereby preventing legitimate network traffic.
- Disrupt a server by sending more requests than it can possibly handle, thereby preventing access to a service.





Denial of Service (DoS) Attack

DoS example you are familiar with ☺

- A party of 100 seats is being organized, on a first-come first-serve basis.
- 100 naughty guys send letters to request invitations, but the letters have false return addresses.
- 100 invitations are mailed to these fake addresses, so nobody receives the invitations.
- There are **no invitations left** because all the invitations have been reserved for the unknown 100 people.

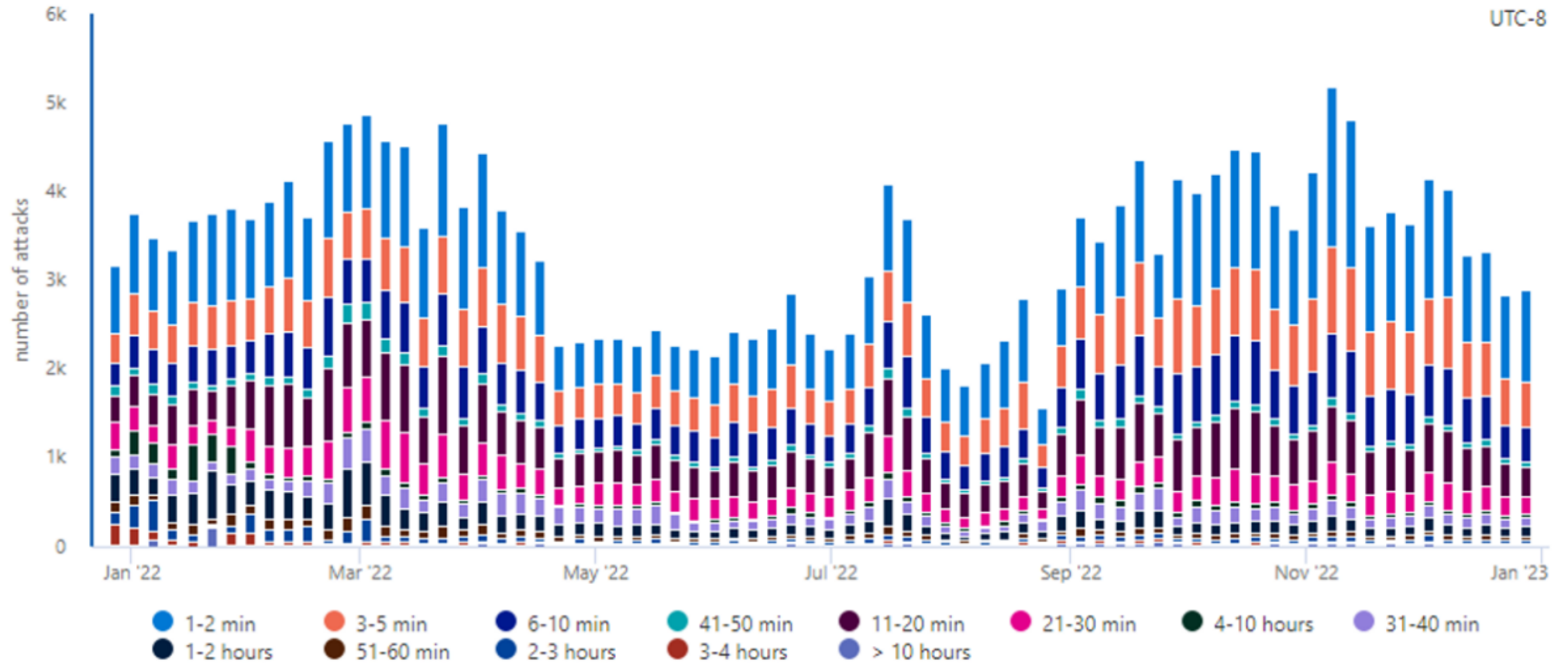




Denial of Service (DoS) Attack



DDoS impact





Denial of Service (DoS) Attack



DoS attack types

- **SYN Flood (TCP)**
- **Smurf Attack (ICMP Flood)**
- LAND Attack
- UDB Flood
- **Trinoo (DDoS)**
- Tribal Flood Network (TFN &TFN2K)
- Stacheldraht

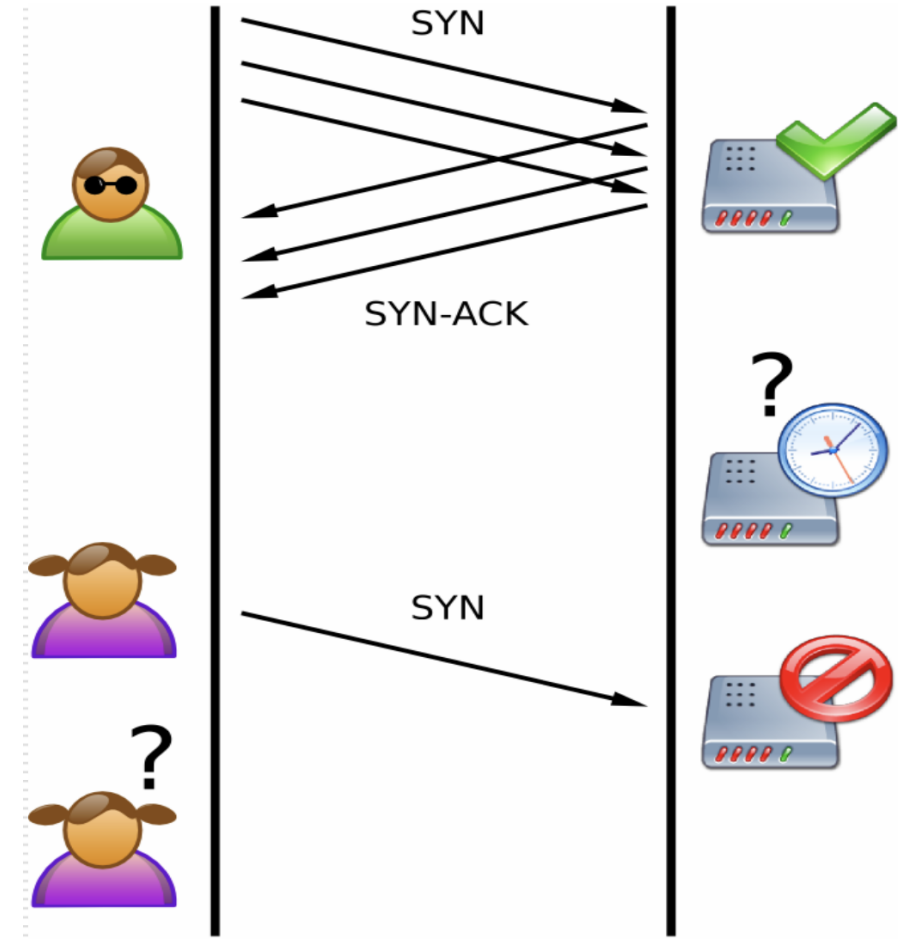


Denial of Service (DoS) Attack



SYN Flood (TCP)

- Attacker sends a flood of TCP/SYN packets
- Server spawns a half-open connection, by sending back a TCP/SYN-ACK packet, and waiting for an TCP/ACK packet in response from the sender address.
- No one replies to SYN-ACK, the response never comes.
- Half-open connections consume resources on the server and limit the number of legitimate connections the server.



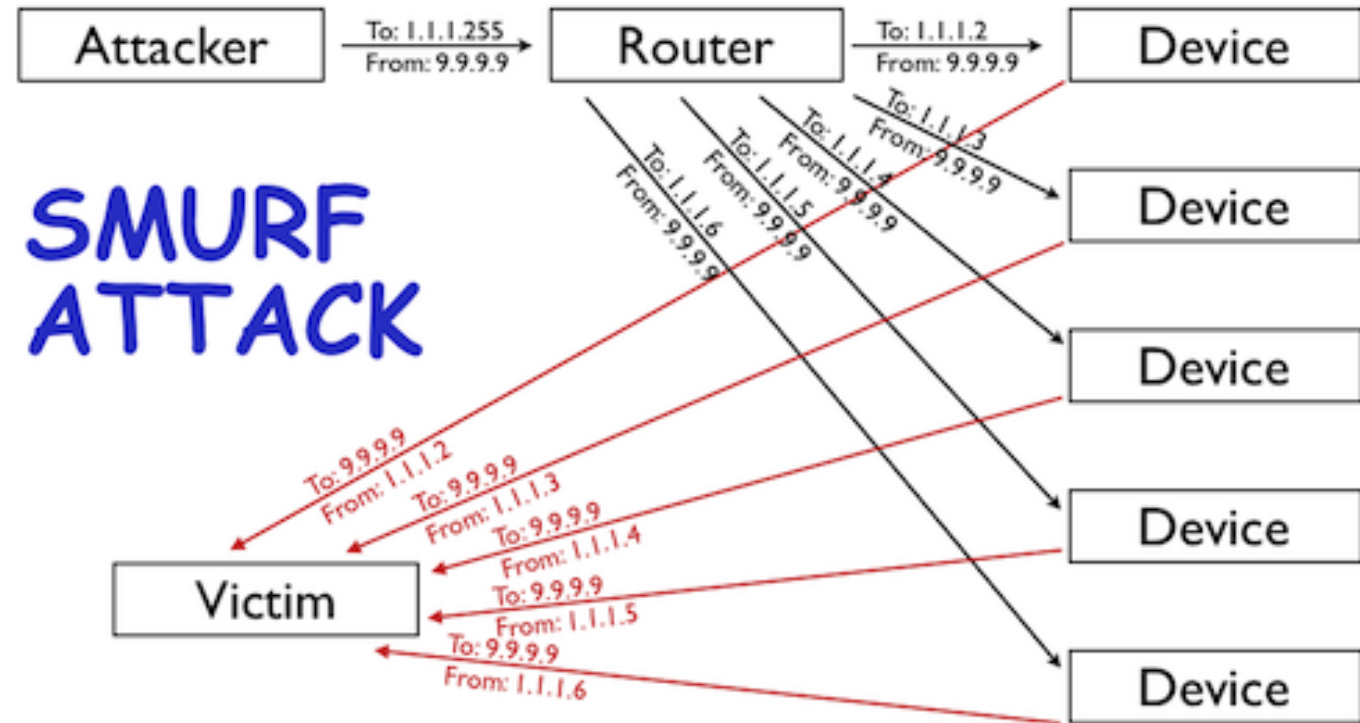


Denial of Service (DoS) Attack



Smurf Attack (ICMP Flood)

1. Attacker sends a flood of Ping requests from a compromised computer. Ping request has:
 - *sender address is the victim IP*
 - *destination address is the network broadcast address*
2. Router broadcasts the Ping in the network
3. All receivers send replies to victim





Denial of Service (DoS) Attack

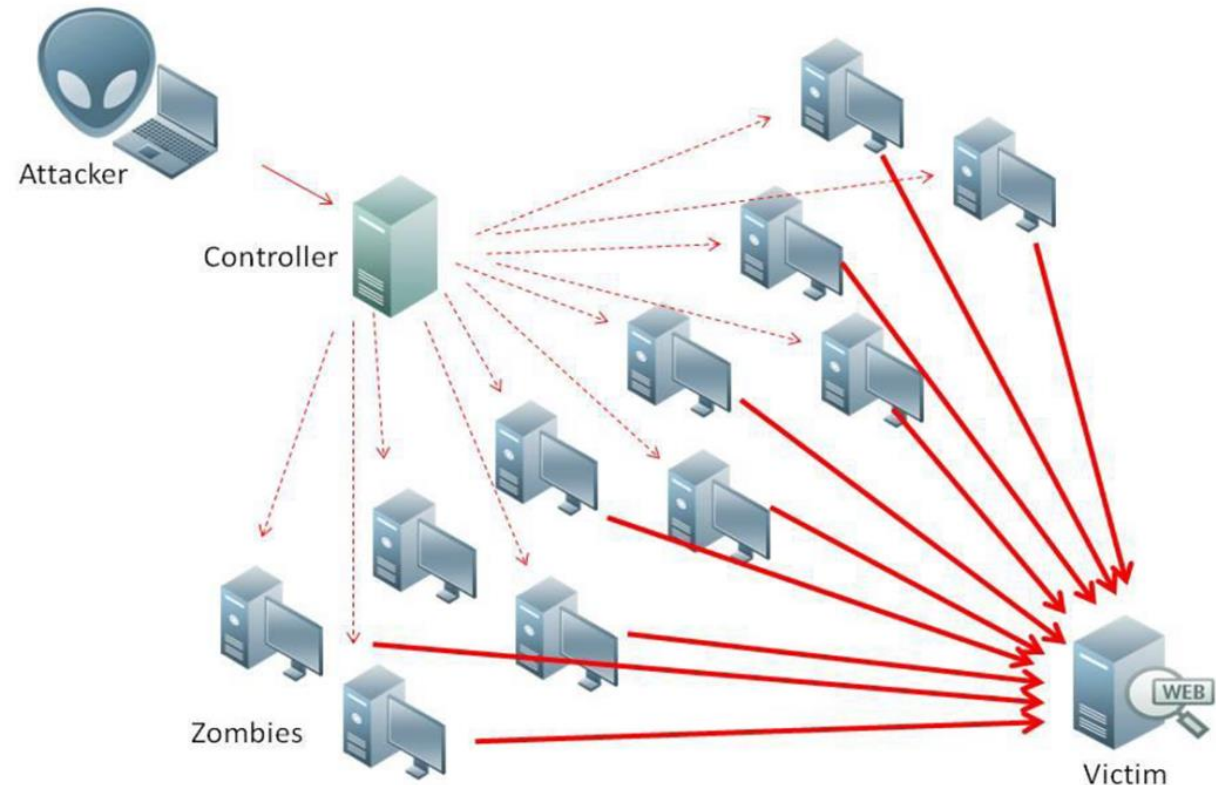


What is a Distributed Denial of Service (DDoS) attack?

A Distributed Denial of Service (DDoS) attack uses many computers to launch a **coordinated DoS attack** against one or more targets.

Example: Trinoo attack

1. Attacker installs a DDoS master program on a computer using a stolen account.
2. Master installs (thousands) of agents as Zombies (on compromised machines). All agents send requests to Victim.
3. Master launches the agents (e.g., thousands)

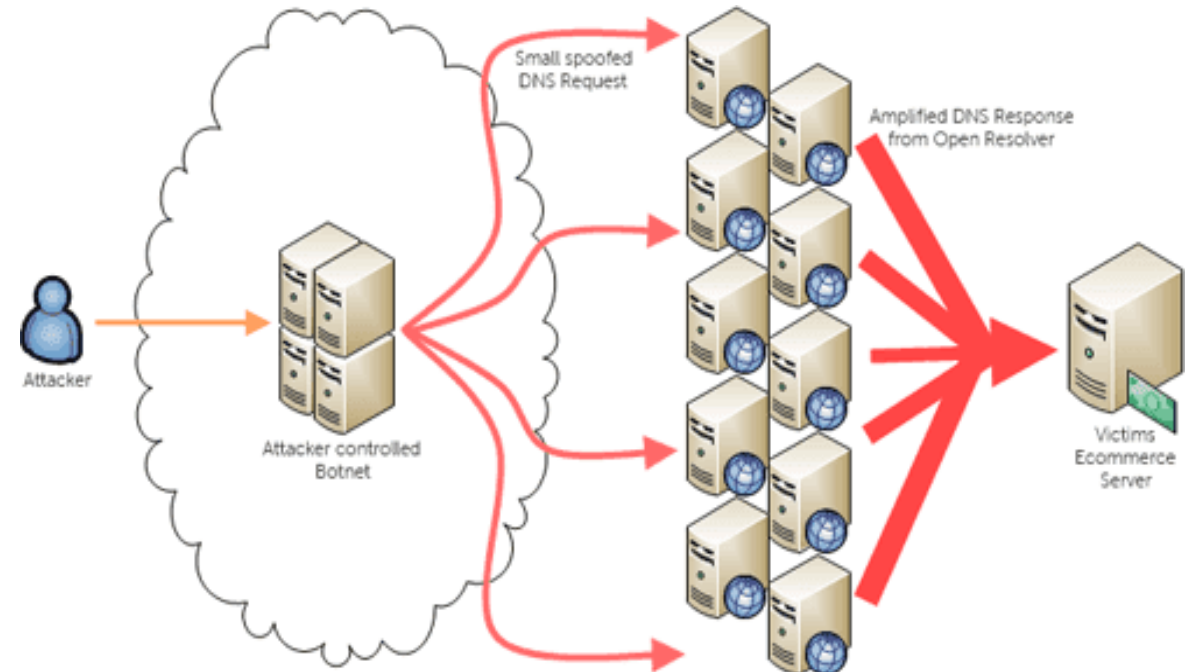




Using DNS for DDoS Amplification attacks

- DNS primarily uses the (spoofable) UDP protocol
- Most DNS responses are larger than the requests
- DNS is used in reflection attacks

Back to this





Denial of Service (DoS) Attack



DDoS Mitigations

- Prevent Initial Hack
- Use of Firewalls
 - *Use firewalls for filtering low-volume and protocol-based attacks, not volumetric floods.*
- Use a server farm and load balancer to offset the effects of a DDoS attack
 - *Distributes traffic*
 - *Improves availability*
 - *Increase capacity*
 - *Improve fault tolerance*



Denial of Service (DoS) Attack



DDoS Mitigations

- Check Ingress/Egress Packets
 - *Implement ingress and egress filtering to block spoofed or abnormal traffic patterns.*
- Prevent SYN flood attacks by discarding the first SYN packet (causes delay for legitimate users)
 - *SYN cookies*
 - *SYN rate limiting*
 - *TCP backlog tuning*
- Change IP address of attacked system (problem for updating legitimate users of new system IP address)
 - *Temporary mitigation in limited scenarios; not a sustainable DDoS defense*



Denial of Service (DoS) Attack



DDoS Mitigations

A modern, accurate DDoS mitigation list **must include**:

- DDoS scrubbing centers
- CDN-based absorption
- Rate limiting at ISP level
 - *Internet Service Providers enforce traffic thresholds to limit excessive requests, preventing large-scale floods from overwhelming customer networks.*
 - *NCA requires organizations to subscribe to two ISPs to eliminate single points of failure, improve resilience against DDoS and routing attacks, and ensure continuous availability of critical services through infrastructure diversity.*
 - *Traffic diversion during attacks*
 - *Load sharing (active-active)*
 - *Controlled failover (active-passive)*
- Cloud DDoS protection services

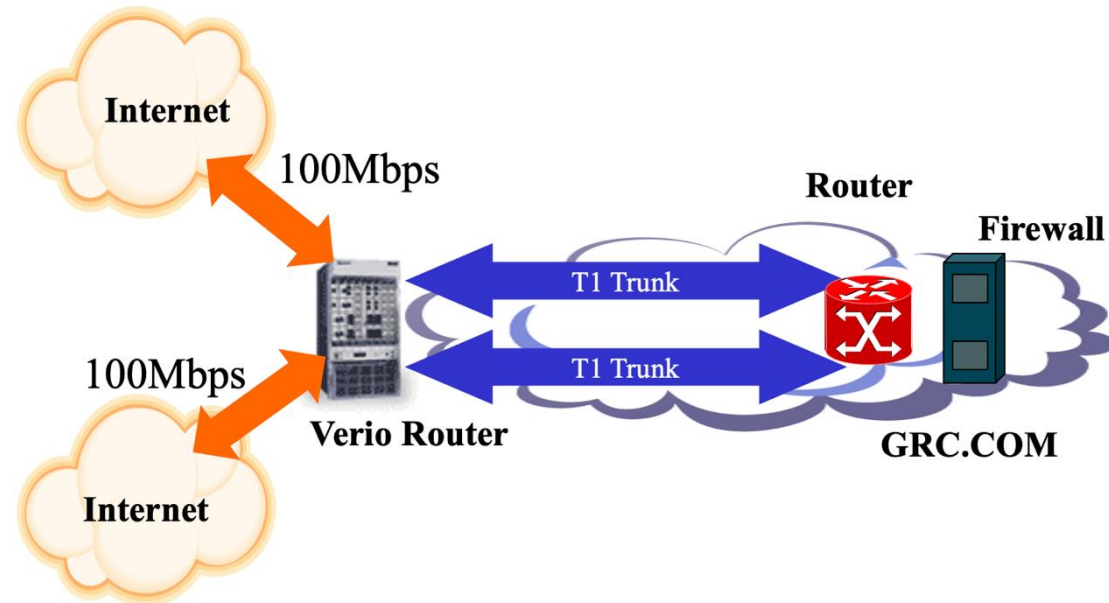


Denial of Service (DoS) Attack



Case Study: DDoS on GRC.COM (1/4)

- Gibson Research Corporation (GRC)
- Provides free internet security testing software: Shields Up, LeakTest, etc.
- Attacked in May 2001 by a DDoS attack using 474 zombie machines.
- Both T1 trunks are fully saturated



(Source: Princeton University Prof. Ruby Lee team)

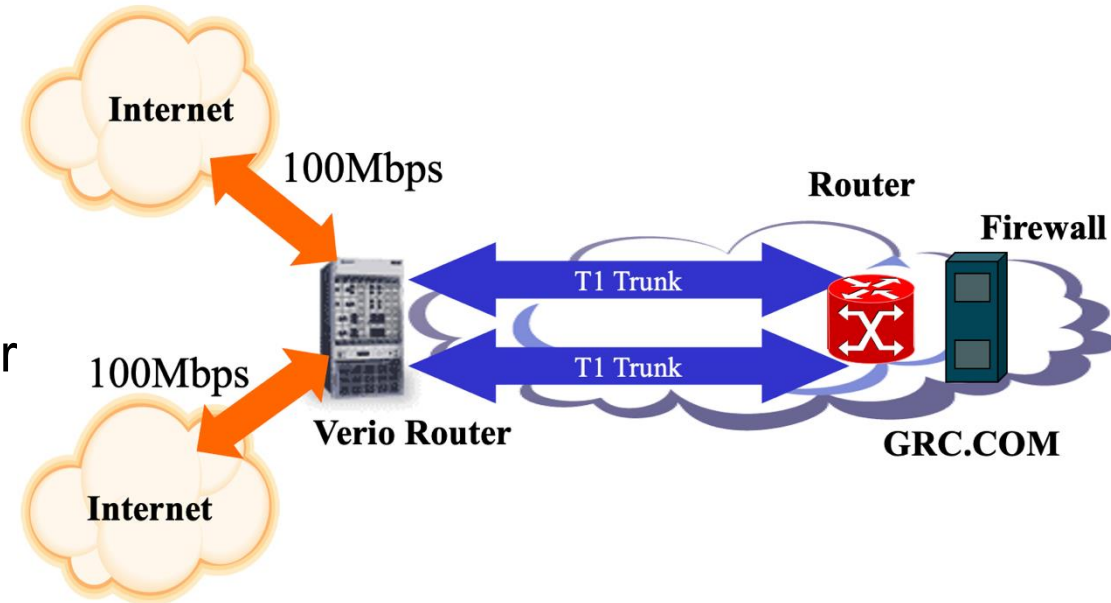


Denial of Service (DoS) Attack



Case Study: DDoS on GRC.COM (2/4)

- May 4, 2001, GRC.COM Dropped Off of the Internet.
- GRC uses a packet sniffer to see the malicious packets and asks its ISP, Verio to filter them.
- After 17hours GRC.com was back online, however the attacks continued.



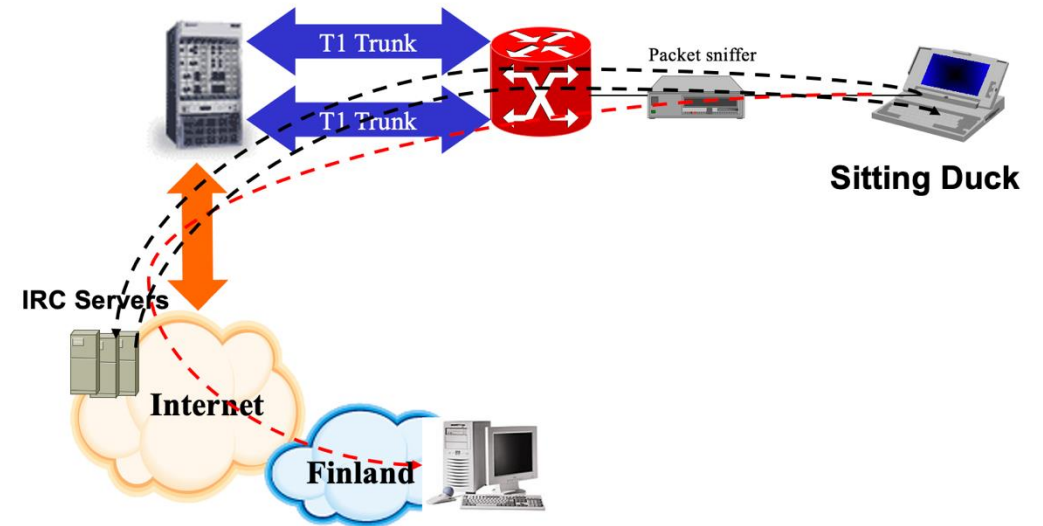


Denial of Service (DoS) Attack



Case Study: DDoS on GRC.COM (3/4)

- After 2 weeks now
- GRC then receives an anonymous e-mail in their web-based Spyware drop box which contains the “Zombie” (DDoS Daemon).
- GRC sets up “Sitting Duck” dummy computer running DDoS daemon to understand what happens.
- “Sitting Duck” successfully connects to IRC chat server, gets instructions to attack a system in Finland.





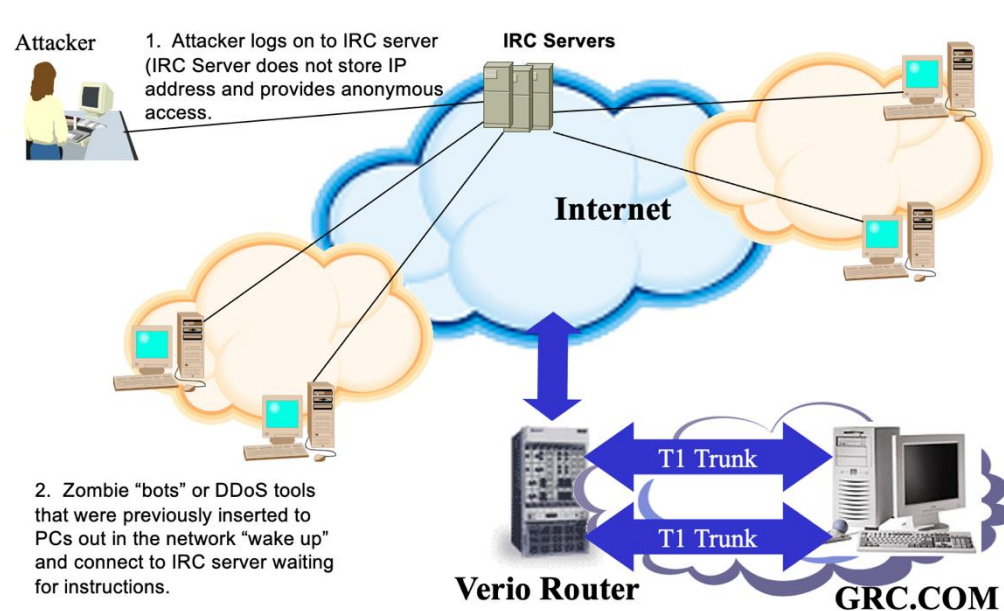
Denial of Service (DoS) Attack



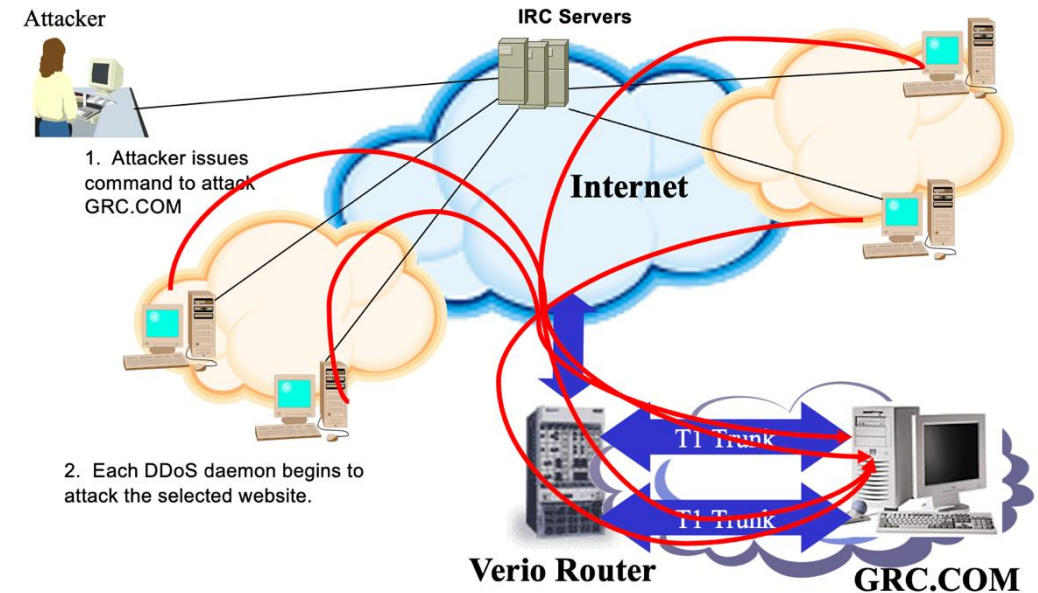
Case Study: DDoS on GRC.COM (4/4)

Investigation concludes what happened:

Phase 1. Attack Preparation



Phase2. Attack Initiation



Do you have any questions?



rc3.kaust.edu.sa



Follow us @rc3kaust

